Halotrcer report

Target http://127.0.0.1:18089/v1 · 2026-10-20 12:00 UTC · halotrcer test
Tokvera v0.1.0-dev (ok) · Sievant v0.1.0-157-gd8a8bcf (ok)

> tokvera v0.1.0-dev is outside the versions this release supports (>=0.2.0 <0.3.0)

Executive summary

Efficiency grade (Tokvera): D · Provisional scoring · reliability concern
Cost per 1,000 requests: not computed
Agent security (Sievant): 1 critical, 3 high · deal risk: 4 finding(s)

> Reliability concern: Tokvera graded this endpoint D. Shown beside the grade; it is not counted as deal risk.

Top 5 findings, ranked by business impact

1. Hard-coded Slack token
Sievant SEC001 · security · deal risk · server slack · env.SLACK_BOT_TOKEN · critical security finding (Sievant SEC001)
Fix: Move it to the environment or a secret store and reference it (for example ${SLACK_BOT_TOKEN}); then rotate it, since it has been on disk.

2. Literal value in secret-named field X-API-Key
Sievant SEC002 · security · deal risk · server api · headers.X-API-Key · deal risk: a customer security review would flag Sievant SEC002 (high)
Fix: Reference it from the environment (for example ${X_API_KEY}) and rotate it.

3. Credential embedded in the server URL
Sievant SEC004 · security · deal risk · server cap-remote · url · deal risk: a customer security review would flag Sievant SEC004 (high)
Fix: Rotate the URL with the provider if it has been shared, keep the file private, and prefer a provider option that authenticates with a header referenced from the environment.

4. Credential embedded in the server URL
Sievant SEC004 · security · deal risk · server notes · url · deal risk: a customer security review would flag Sievant SEC004 (high)
Fix: Rotate the URL with the provider if it has been shared, keep the file private, and prefer a provider option that authenticates with a header referenced from the environment.

5. Time to first token collapses under load
Tokvera ttft_p99_load_ratio · latency · Tokvera fail on latency, impact 35 grade points (at or above the median 20)
Fix: Find the saturation point in the level table and keep traffic below it: raise the server's batch and concurrent-sequence limits if memory allows, add replicas behind the endpoint, or put an admission limit in front so excess requests fail fast instead of queueing.

Cost & performance

From Tokvera: http://127.0.0.1:38409/v1 · model tokvera-sim-demo

> Simulated: Tokvera measured its built-in demo server; these numbers describe no real endpoint.

Efficiency grade: D (60.8 / 100, scoring 0.9.0)

Provisional scoring. The weights and thresholds are provisional: they have not yet been calibrated against real pilot scans and may change before scoring 1.0.0.
capped at D: more than 5% of requests failed
capped at C: time to first token collapses under load
Requests: 60 sent, 55 succeeded, 5 failed, in 0.8 s.

Concurrency	Requests	Failed	TTFT p50	TTFT p95	TTFT p99	Duration p95
1	12	0	11.0 ms	11.0 ms	11.0 ms	18.0 ms
2	12	2	11.0 ms	11.0 ms	11.0 ms	18.0 ms
4	12	2	11.0 ms	11.0 ms	11.0 ms	18.0 ms

8	12	1	11.0 ms	201 ms	201 ms	208 ms
16	12	0	201 ms	201 ms	201 ms	208 ms

Cost

Cost: not computed. not computed: the rate sheet has no rate for self_hosted/tokvera-sim-demo

Findings

Time to first token collapses under load · fail · -35 grade points · effort 2–5 days

p99 201 ms at concurrency 16 against 11 ms at concurrency 1

The tail grows much faster than the load: requests are queueing behind each other, so the slowest users see a multiple of the idle latency at the concurrency your traffic reaches.

Fix: Find the saturation point in the level table and keep traffic below it: raise the server's batch and concurrent-sequence limits if memory allows, add replicas behind the endpoint, or put an admission limit in front so excess requests fail fast instead of queueing.

Requests are failing · fail · -30 grade points · effort 0.5–3 days

5 of 60 requests failed (HTTP 429 ×5)

Every failed request is either a user-visible error or a retry that costs latency and money. The status breakdown in the evidence says whether it is rate limiting, timeouts or server errors.

Fix: For 429s, raise the rate limit or add client-side retry with exponential backoff and jitter. For timeouts, compare the request timeout with the measured request duration. For 5xx, read the server logs at the times of the scan.

Many prompts repeat exactly · fail · -10 grade points · effort 1–3 days

16 of 40 prompts in the demo sample repeat an earlier one exactly

If this sample is what reaches the model, every repeat is a paid call whose answer was already computed once.

Fix: Put an exact-match response cache (keyed on the normalized prompt and model parameters, with a TTL) in front of the model for the repeating routes, and measure the hit rate before considering a semantic cache.

No Prometheus metrics at /metrics · warn · -5 grade points · effort 0.5 days

no Prometheus exposition answered at /metrics on the target's origin

Queue depth, batch size and cache usage are what explain a latency problem. Without them, a slowdown can be seen but not diagnosed.

Fix: Enable the server's metrics endpoint (llama.cpp needs `--metrics`; vLLM and TGI serve /metrics by default) and scrape it. If the endpoint sits behind a gateway, expose the metrics there.

Tokvera contacts only the target you specify, plus GitHub when you run update or doctor --check-update, and tokvera.halotrcer.com and GitHub for the plugin's first-run install.

The load used Tokvera's fixed, harmless benchmark prompts. Response text was read for timing and discarded; none is stored in this report.

Agent security

From Sievant: the MCP server configuration of the AI clients on this machine.

custom · testdata/scan/cursor-mcp.json · file · 4 server(s), 4 not behind Sievant

custom · testdata/scan/vscode-mcp.jsonc · file · 2 server(s), 2 not behind Sievant

Findings: 1 critical, 3 high, 1 medium, 0 low, 0 info.

Critical: Hard-coded Slack token (SEC001) · deal risk

custom · testdata/scan/cursor-mcp.json · server slack · env.SLACK_BOT_TOKEN

Evidence (masked): xoxb… (28 chars)

Fix: Move it to the environment or a secret store and reference it (for example ${SLACK_BOT_TOKEN}); then rotate it, since it has been on disk.

High: Literal value in secret-named field X-API-Key (SEC002) · deal risk

custom · testdata/scan/vscode-mcp.jsonc · server api · headers.X-API-Key

Evidence (masked): lite… (21 chars)

Fix: Reference it from the environment (for example ${X_API_KEY}) and rotate it.

High: Credential embedded in the server URL (SEC004) · deal risk

custom · testdata/scan/cursor-mcp.json · server cap-remote · url

Evidence (masked): https://mcp.capability.example/apps/{masked:22}/mcp

Fix: Rotate the URL with the provider if it has been shared, keep the file private, and prefer a provider option that authenticates with a header referenced from the environment.

High: Credential embedded in the server URL (SEC004) · deal risk

custom · testdata/scan/cursor-mcp.json · server notes · url
Evidence (masked): https://mcp.example.com/sse{masked:16}
Fix: Rotate the URL with the provider if it has been shared, keep the file private, and prefer a provider option that authenticates with a header referenced from the environment.

Medium: Server runs with all permissions (Deno) (PERM003)
custom · testdata/scan/cursor-mcp.json · server deno · args[1]
Evidence (masked): --allow-all
Fix: Grant only the access the server needs (for Deno, --allow-net=<hosts>; for containers, a dedicated network).

Tool descriptions, and the resources and prompts each server offers, were not checked: that needs starting the servers (sievant scan --inspect-tools, which runs them).

30-day fix plan

Week 1: critical exposure and quick fixes

• Hard-coded Slack token (Sievant SEC001)
Move it to the environment or a secret store and reference it (for example ${SLACK_BOT_TOKEN}); then rotate it, since it has been on disk.
• Literal value in secret-named field X-API-Key (Sievant SEC002)
Reference it from the environment (for example ${X_API_KEY}) and rotate it.
• Credential embedded in the server URL (Sievant SEC004)
Rotate the URL with the provider if it has been shared, keep the file private, and prefer a provider option that authenticates with a header referenced from the environment.
• Credential embedded in the server URL (Sievant SEC004)
Rotate the URL with the provider if it has been shared, keep the file private, and prefer a provider option that authenticates with a header referenced from the environment.
• No Prometheus metrics at /metrics (Tokvera metrics_endpoint)
Enable the server's metrics endpoint (llama.cpp needs `--metrics`; vLLM and TGI serve /metrics by default) and scrape it. If the endpoint sits behind a gateway, expose the metrics there.

Week 2: the largest cost and latency failures

• Time to first token collapses under load (Tokvera ttft_p99_load_ratio)
Find the saturation point in the level table and keep traffic below it: raise the server's batch and concurrent-sequence limits if memory allows, add replicas behind the endpoint, or put an admission limit in front so excess requests fail fast instead of queueing.
• Requests are failing (Tokvera error_rate)
For 429s, raise the rate limit or add client-side retry with exponential backoff and jitter. For timeouts, compare the request timeout with the measured request duration. For 5xx, read the server logs at the times of the scan.

Week 3: remaining high-severity security findings

Nothing this week.

Week 4: everything else

• Many prompts repeat exactly (Tokvera repeat_prompt_share)
Put an exact-match response cache (keyed on the normalized prompt and model parameters, with a TTL) in front of the model for the repeating routes, and measure the hit rate before considering a semantic cache.
• Server runs with all permissions (Deno) (Sievant PERM003)
Grant only the access the server needs (for Deno, --allow-net=<hosts>; for containers, a dedicated network).

How to read this report

Halotrcer's ranking across the two tools is provisional (scoring version 0.1.0): its tiers are judgement, not calibrated. See docs/scoring.md.

Halotrcer contacts only the target you give it (through Tokvera) and reads only the MCP configuration files Sievant reads, on this machine. It sends no telemetry. Secrets stay masked as each tool masks them; on top of that, Halotrcer drops URL credentials and query strings, hides environment values, shows your home directory as ~ and replaces your user name with <user>.